



Cybersecurity

Agenda

- Useful information
- Semestral agenda
- Basic terms and definitions

Cybersecurity

Useful information

Contact:

Grzegorz Kołaczek
room 116 building C3
Tel. +48713203589
E-mail: Grzegorz.Kolaczek@pwr.edu.pl

Cybersecurity

Useful information

Here you will find everything you wanted to ask, but were afraid to do so:

Lectures, Labs:

- Web page: <http://eportal.pwr.edu.pl/>
- Course name: **Cybersecurity**

Cybersecurity

Useful information

Grading:

- Lecture -> Exam (online - eportal)
 - T0 – last lecture in the semester (03.02.2026)
 - T1 – 06.02.2026 11am-1pm, in A1 329
 - T2 – 13.02.2026 11am-1pm, in C3 22
- If you prefer the classical human-to-human conversation as an exam form, just let me know before 30.10.2025
- Labs -> follow the guidelines of your lab's teachers
 - the laboratory grade does not affect the lecture grade
- Attendance at the lecture is not obligatory.
- content discussed during the lecture will appear on the exam
- lecture material will be uploaded to the eportal after class
- technical details concerning the examination (e.g. number of questions, time, form, etc.) will be presented during the last but one lecture.

Cybersecurity

Semestral Agenda

- More or less we will follow subsequent topics:
 - Cryptography
 - Public and private key cryptography, authentication, secure channels, PKI...
 - Application Security
 - Defensive programming, memory protection, buffer overflows,
 - Web Security
 - Web architecture, web attacks, web defenses
 - Network Security
 - IP,TCP,routing,network protocols,network attacks, network defense

Cybersecurity

Useful information

Textbook (useful but not obligatory):

- Computer Security and the Internet: Tools and Jewels by Paul C. van Oorschot. 2019, Springer. 365 pages plus frontmatter. ISBN: 978-3-030-33648-6 (hardcopy), 978-3-030-33649-3
<https://people.scs.carleton.ca/~paulv/toolsjewels.html>
- Security Engineering, Ross J. Anderson
<https://www.cl.cam.ac.uk/~rja14/book.html>
- Handbook of Applied Cryptography, A. J. Menezes, P. C. van Oorschot, and S. A. Vanstone
<http://cacr.uwaterloo.ca/hac/>
- Boneh, D., & Shoup, V. (2020). A graduate course in applied cryptography.
<http://toc.cryptobook.us>
- Computer Security: Art and Science, 2nd Edition. Matt Bishop
<https://learning.oreilly.com/library/view/computer-security-art/9780134097145/>

Cybersecurity

Useful information

Even more interesting readings:

- An Introduction to Computer Security: The NIST Handbook
<http://csrc.nist.gov/>
- Zalewski M. (2009), Browser Security Handbook,
<https://code.google.com/archive/p/browsersec/wikis/Main.wiki>
- Wheeler D., (2015). Secure Programming HOWTO - Creating Secure Software,
<https://dwheeler.com/secure-programs/>
- Katz, J., & Lindell, Y. (2014). Introduction to modern cryptography. Chapman and Hall/CRC.
http://staff.ustc.edu.cn/~mly/moderncrypto/reading%20materials/introduction_to_Modern_Cryptography.pdf
- Kumar, A., & Bose, S. (2017). Cryptography and network security. Pearson Education India.
- Rosulek M., The Joy of Cryptography, Undergraduate textbook,
<http://web.engr.oregonstate.edu/~rosulekm/crypto/>
- S. Goldwasser and M. Bellare, Lecture Notes on Cryptography
<https://cseweb.ucsd.edu/~mihir/papers/gb.html>

Cybersecurity

Basic Problems

Why do I need to study security related issues?

Cyberbezpieczeństwo

Typical day in cybersecurity....

The story of the great Polish train hack

Polish rolling stock company Newag has alleged its train systems were illegally hacked, making four of its trains unusable.

Patrick Rhys Attack December 15, 2023

YubiKeys Are a Security Gold Standard—but They Can Be Cloned

Security researchers have discovered a cryptographic flaw that leaves the YubiKey 5 vulnerable to attack.

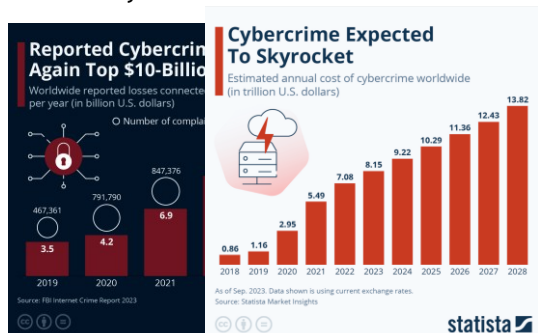
Millions of Vehicles Could Be Hacked and Tracked Thanks to a Simple Website Bug

RED LINE
JOHN GREENBERG

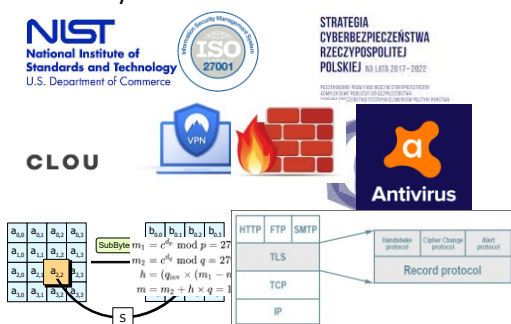
First Israel's Exploding Pagets Maimed and Killed. Now Comes the Paranoia

KNICK-IN EFFECTS
JOHN GREENBERG

Is it worthy to think-learn about?



That's why all we need is...



Cybersecurity

Basic Problems

- What is the goal of Cybersecurity?
- Definition:
To prevent or detect unauthorized actions by users of the system.

Cybersecurity

Basic Problems

- Cybersecurity will reinforce its positions
 - The range of threats is enormous; therefore the discussion of the cybersecurity related issues will continue.
 - The consumers have a growing awareness of the value of their information.
 - Governments are actively planning, developing and adopting regulations on cybersecurity in this regard. Due to some cases of violation of the [General Data Protection Regulation \(GDPR\)](#) and loud scandals concerning Google and Facebook the application of enforcement measures is expected.

Cybersecurity

Basic Problems

- In computer science education, you learn to design and program code, but security education still falls short.
- Simple programming mistakes lead to serious security problems
- The problem worsens the more GAI is used.
- Failing to protect yourself and not being security-aware can be very costly
- Number of security-related incidents on the Internet increasing fast

Cybersecurity

Basic Problems

- **You spend X so that your opponent has to spend Y to do something you don't want them to do**
 - Y is rarely greater than X
- **It's all a resource game**
 - Time
 - \$\$\$
 - Computational power (time x \$\$\$)
- **Implication:**
 - Given enough resources, someone's going to get in
 - Given enough attackers, someone's going to get in
 - Given enough time, someone's going to get in
 - Thus all systems can and will fail
- **The trick is to raise the bar to an adequate level of (in)security for the resource you are trying to protect**

Cybersecurity

Basic Problems

- How do we achieve Cybersecurity goals:
 - Security principles/concepts: explore general principles/concepts that can be used as a guide to design secure information processing systems.
 - Physical/Organizational security: consider physical & organizational security measures (policies)
 - Security mechanisms: explore some of the security mechanisms that can be used to secure information processing systems.

Cybersecurity

Basic Problems

Goals of Security

- **Prevention**
 - To prevent someone from violating a security policy
- **Detection**
 - To detect activities in violation of a security policy
 - Verify the efficacy of the prevention mechanism
- **Recovery**
 - Stop policy violations (attacks)
 - Assess and repair damage
 - Ensure availability in presence of an ongoing attack
 - Fix vulnerabilities for preventing future attack
 - Retaliation against the attacker

Cybersecurity

Basic Problems

- Security,
- Safety,
- Reliability,
- Assurance,
- ...

Cybersecurity

Basic Problems

Security

- Cybersecurity is information security as applied to computers and networks.
- The field covers all the processes and mechanisms by which computer-based equipment, information and services are protected from:
 - unintended or unauthorized access,
 - change or destruction.
- Cybersecurity also includes protection from unplanned events and natural disasters

Cybersecurity

Basic Problems

- Security:
 - Confidentiality
 - Integrity
 - Availability
 - Additionally:
 - Authenticity, accountability, reliability, safety, dependability, survivability . .

Cybersecurity

Confidentiality

- Historically, security is closely linked to *secrecy*.
- Security involved a few organizations dealing mainly with classified data.
- However, nowadays security extends far beyond confidentiality.
 - Confidentiality involves:
 - *privacy*: protection of private data,
 - *secrecy*: protection of organizational data.

Cybersecurity

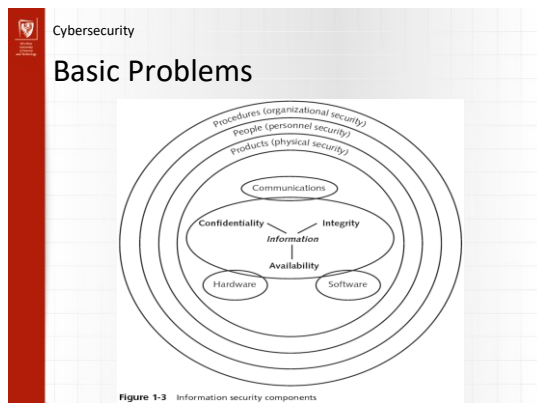
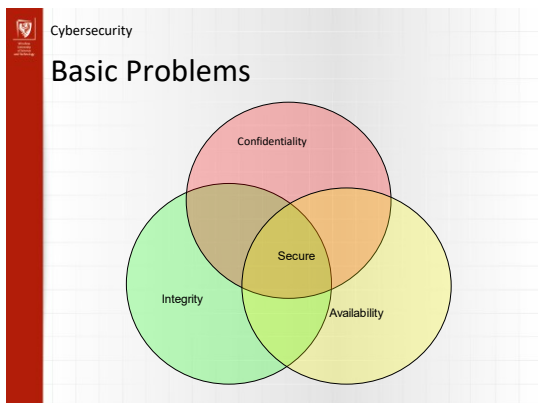
Integrity

- “Making sure that everything is as it is supposed to be”
- For Cybersecurity this means:
 - *Preventing unauthorized writing or modifications.*

Cybersecurity

Availability

- For Computer Systems this means that:
 - *Services are accessible and useable (without undue delay) whenever needed by an authorized entity in accordance with security policy*
- For this we need *fault-tolerance*.
- Faults may be *accidental* or malicious.
- Denial of Service attacks are an example of malicious attacks.



Cybersecurity

Accountability

Actions affecting security must be traceable to the responsible party.

For this,

- Audit information must be kept and protected
- Access control is needed

Cybersecurity

Other requirements

- **Reliability**
 - deals with accidental damage,
- **Safety**
 - deals with the impact of the environment on system failure
- **Survivability**
 - deals with the recovery of the system after massive failure.

Cybersecurity

Other requirements

- **Assurance**
 - indicate “how much” to trust a system and is achieved by ensuring that
 - the required functionality is present and correctly implemented
 - there is sufficient protection against unintentional errors
 - there is sufficient resistance to intentional penetration or by-pass
- Basis for determining this aspect of trust
 - Specification
 - Requirements analysis
 - Statement of desired functionality
 - Design
 - Translate specification into components that satisfy the specification
 - Implementation
 - Programs/systems that satisfy a design

Cybersecurity

Other requirements

- **Authenticity**
 - ensure that the data, transactions, communications or documents (electronic or physical) are honest
- **Non-repudiation**
 - party of a transaction cannot deny having received a transaction nor can the other party deny having sent a transaction.



Cybersecurity

Security Principles

- Article by Saltzer and Schroeder
„The Protection of Information in Computer Systems”
(1975)
– http://www.acsac.org/secsheff/papers/protection_information.pdf
- Eight principles underlying design and implementation of security mechanisms
- These are *guidelines*, not hard and fast rules
- Not exhaustive



Cybersecurity

Security Principles 1

- “Principle of least privilege”
 - A subject should be given *only* the privileges it needs to accomplish its task
 - E.g., only allow access to information it needs
 - E.g., only allow necessary communication
 - The *function* of a subject (not its identity) should determine this
 - I.e., if a subject needs some privileges to complete a specific task, it should relinquish those privileges upon completion
 - If reduced privileges are sufficient for a given task, the subject should request only those privileges



Cybersecurity

Security Principles 1

- There is a limit to how much granularity a system can handle
- Systems are often not designed with the necessary granularity
 - E.g., “append” may not be distinct from “write”
 - E.g., in UNIX, nothing between *user* and *root*
 - Anyone who can make backup files can also delete those files



Cybersecurity

Security Principles 2

- “Principle of Fail-Safe Defaults”
 - Unless a subject is given explicit access to an object, it should be denied access
 - I.e., the default is no access
 - More generally, in case of ambiguity the system should default to the more restrictive case



Cybersecurity

Security Principles 3

- “Economy of Mechanism”
 - Security mechanisms should be as simple as possible...
 - This applies to both the policy and the mechanism!
 - Less chance of error
 - Can simplify assurance process
- Offering too much functionality can be dangerous
 - E.g., finger protocol: how much information can be returned, or allow an arbitrary amount?
 - DoS attack by returning an infinite stream of characters
 - E.g., macros in Excel, Word
 - E.g., postscript can execute arbitrary code



Cybersecurity

Security Principles 4

- “Principle of Complete Mediation”
 - All accesses to objects should be checked to ensure they are allowed
 - OS should mediate any request to read an object --- even on the second such request by the same subject!
 - Don’t cache authorization results
 - Don’t rely on authentication/authorization performed by another module
 - Time-of-check-to-time-of-use flaws...
- Good examples: re-authentication (on websites, or systems) when performing sensitive tasks



Cybersecurity

Security Principles 4

- In UNIX, when a process tries to read a file, the system checks access rights
 - If allowed, it gives the process a file descriptor
 - File descriptor is presented to OS for access
- If permissions are subsequently revoked, the process still has a valid file descriptor!
 - Insufficient mediation



Cybersecurity

Security Principles 5

- “Open Design”
 - No “security through obscurity”
 - Security of a system should not depend on the secrecy of its implementation
 - Of course, secret keys do not violate this principle!



Cybersecurity

Security Principles 6

- “Separation of Privilege”
 - (As much as is feasible...) a system should not grant permission based on a single condition
 - E.g., require more than one sys admin to issue a critical command



Cybersecurity

Security Principles 7

- “Principle of Least Common Mechanism”
 - Minimize mechanisms depended upon by all users
 - Minimize effect of a security flaw!
 - Shared mechanisms are a potential information path, and so may be used to compromise security
 - Shared mechanisms also expose the system to potential DoS attacks



Cybersecurity

Security Principles 8

- “Psychological Acceptability”
 - Security mechanisms should not make access to the resource more difficult
 - If mechanisms are too cumbersome, they will be circumvented!
 - Even if they are used, they may be used incorrectly

Thank you!